

개선 · 권고

제 목 : 기관인증서 및 USB메모리 관리 부적절

담당부서 : 기관인증서 사용부서, 총무전산실

내 용

1. 업무개요

기획평가원 각 부서는 연구관리, 은행거래, 세금신고, 인터넷 거래 등의 업무수행을 위해 부서별로 기획평가원 법인인증서(이하 ‘기관인증서’라 한다)를 보유·사용하고 있으며 감사일 현재(‘21.05.31.) 보유·활용현황은 [표 10]과 같다.

[표 10] 부서별 기관인증서 보유·활용 현황

부서명	보유인원	보유형태	활용업무
총무전산실	3명	USB메모리 : 3개 서버 : 1개	- 용역계약 - 전자문서 유통 - 인터넷 거래(물품구매)
재정관리실	3명	USB메모리 : 4개	- 연구과제 협약 및 연구비 청구 - 은행거래 - 원천세 등 신고
인재경영실	4명	USB메모리 : 4개	- 4대 보험 신고 등 급여관리 - 주민세 납부

* 감사기간 동안 각 부서의 보유현황을 파악한 자료임

한편, 각 부서에서는 기관인증서를 보관하는 등 업무수행을 위하여 USB메모리¹⁾를 총괄부서(총무전산실)에 등록하여 사용하고 있으며, 감사일 현재(‘21.05.31.) 기준 보유 현황은 [표 11]와 같다.

[표 11] 보유 USB메모리 유형 및 등록 수량 현황

구 분	공인인증서용	보안용
등록수량	180	미운영
용도	공인인증서 저장	대외비 자료 저장

1) Universal Serial Bus

2. 사실관계 및 판단기준

기관인증서는 사이버공간에서 기획평가원의 서명이나 인감도장의 역할을 한다.²⁾ 따라서 기관인증서에 대하여 발급방법, 등록, 보관, 사용방법, 대여, 폐기 등에 대한 전반적인 업무표준 및 관리절차가 사전적으로 마련되어 운영되어야 한다.

또한 USB메모리 및 관리시스템을 도입하여 업무에 사용하고자 하는 경우에는 국가정보원 「USB메모리 등 휴대용 저장매체 보안관리지침」에 따라 보안적합성을 확인한 제품을 사용³⁾하여야 하고, USB메모리는 개인서랍이나 캐비닛 등에 안전하게 보관하고, 반·출입을 통제하여야 하며 각 USB메모리에 관리번호⁴⁾를 부여하여 관리하여야 한다.

3. 감사결과 확인된 문제점

가. 기관인증서 관리 업무절차 부재

기획평가원에서는 기관인증서의 발급·사용 등 관리에 대한 기준이 마련되어 있지 않아, 각 부서별로 [표 10]과 같이 필요에 따라 발급하여 공인인증서용 USB메모리에 저장하여 사용하거나, 타 부서 보관 기관인증서를 복사하여 사용하고 있다.

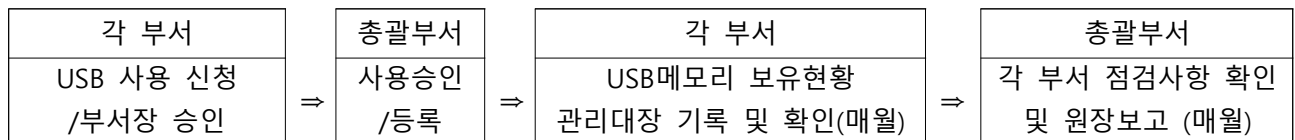
이는 승인받지 않은 업무에 기관인증서를 사용하거나 USB메모리 분실에 따른 위험에 노출되어 있어 조속한 대책 마련이 필요하다⁵⁾.

나. USB메모리 보안관리 부적정

임직원이 개인소유 USB메모리를 기획평가원에서 공인인증서용으로 사용하고자 하는 경우 소속부서장의 결재를 받아 총괄부서(총무전산실)에 사용인가 요구를 하고 총괄부서에서는 보조기억매체(USB메모리 등) 통제시스템(넷헬퍼 V7.0, (주)아이젝스)에 등록하여 사용을 허가하고 있다.

[표 12] USB메모리 신청·인가·관리 절차

-
- 2) 인증서란, 서명이나 인감도장과 같은 역할을 하는 전자서명이 특정인에게 유일하게 속한다는 사실을 확인하고 이를 증명하는 전자적 정보를 말합니다. (출처 : 금융인증센터 홈페이지)
- 3) 국정원 USB메모리 등 휴대용 저장매체 보안관리지침 제4조 ① 각급기관의 장은 상용 암호모듈이 탑재된 휴대용 저장매체 및 휴대용 저장매체 관리시스템을 도입할 경우 그 제품의 안전성을 검증하기 위하여 「국가 정보보안 기본지침」 제2장 제4절에 따라 보안적합성 검증 절차를 이행하여야 한다.
- 4) 국정원 USB메모리 등 휴대용 저장매체 보안관리지침 제8조 ① 휴대용 저장매체는 일반용, 비밀용으로 구분한다. ② 일반용 휴대용 저장매체의 관리요령은 다음과 같다. 5. 관리번호는 팀·과명, 일반, 연번으로 한다. 이 경우 팀·과명은 약칭을 사용할 수 있다.(예 : 총무과-일반-01 등)
- 5) 대구지방법원 2018. 6. 8. 선고 2017나11160판결 : 전자문서에 의한 거래에서 공인인증기관이 발급한 공인인증서에 의하여 본인임이 확인된 자에 의하여 송신된 전자문서는 설령 본인의 의사에 반하여 작성·송신되었다고 하더라도 특별한 사정이 없는 한 전자문서법 제7조 제2항 제2호에 규정된 ‘수신된 전자문서가 작성자 또는 그 대리인과의 관계에 의하여 수신자가 그것이 작성자 또는 그 대리인의 의사에 기한 것이라고 믿을 만한 정당한 이유가 있는 자에 의하여 송신된 경우’에 해당한다고 봄이 타당



그러나 국가정보원의 「USB메모리 등 휴대용 저장매체 보안관리지침」(2019.3.22.) 이 개정되어 [표 13]과 같이 휴대용 저장매체⁶⁾의 관리방법이 변경되었으나, 기획평가원에서는 아직도 이를 내부규정에 반영하지 않고 변경 전 지침을 기준으로 관리하고 있다.

[표 13] 국가정보원 「USB메모리 등 휴대용 저장매체 보안관리지침」 개정현황

구분	2007. 1.	2019. 3. 22.
보조기억 매체 구분	- 일반용, - 비밀용(대외비 포함), - 공인인증서보관용	- 일반용, - 비밀용
공인인증서 보관용 관리방법	- 개인소지 가능 - 공인인증서외 자료저장 불가 - 관리번호 부여 (라벨부착)	- 개인서랍, 캐비넷 등에 보관 - '일반용'에 공인인증서 저장 가능 - 관리번호 부여 (라벨부착)

이에 따라 USB메모리에 대한 반·출입 통제절차가 시행되지 않아 USB메모리를 휴대하여 반·출입하고 있으며, 관리번호가 포함된 라벨을 USB메모리에 부착하여 관리하고 있지 않다.

또한 감사일 현재 보유하고 있는 보안 USB메모리(UTMP 2.0 (주)채울)도 인증기간 만료일(2020년 8월 23일)이 경과한 제품이며, 공인인증서용 USB메모리 통제시스템도 「국가 정보보안 기본지침」 제2장 제4절에 의한 보안적합성 검증 절차를 이행하지 않은 제품을 사용하고 있다.

이러한 USB메모리 관리방식은 자료의 외부 유출, 악성프로그램의 침입 및 분실 시 자료 보호 등에 취약함으로 USB메모리의 안전한 사용과 관리를 위한 대책마련이 필요하다.

6) USB메모리 등 휴대용 저장매체 보안관리지침 제3조(정의) 1. “휴대용 저장매체”라 함은 디스켓·CD·외장형 하드디스크·USB메모리 등 정보를 저장할 수 있는 것으로 PC·서버 등의 정보시스템과 분리할 수 있는 기억장치를 말한다.

관계자 의견 및 검토결과

관련부서에서는 기관인증서 관리기준 마련 필요성에 대해 동의하였으며, USB메모리 관리에 대하여도 관련규정에 따라 업무 처리를 철저히 하겠다는 의견을 제시하였다.

조치할 사항 한국과학기술기획평가원장(총무전산실장)은

- ① 기관인증서의 철저한 관리를 위하여 발급, 공유, 활용, 보관, 폐기 등을 포함하는 관련 규정 등을 개정·시행하여 주시기 바라며, (개선)
- ② 「USB메모리 등 휴대용 저장매체 보안관리지침」을 개정된 국가정보원 지침을 반영하여 개정하고, USB메모리를 사용함에 있어 자료의 외부 유출, 악성프로그램의 침입 및 분실 시 자료 보호 등 기획평가원의 정보보호를 위해 국가정보원 보안인증 제품 사용, 반·출입통제 및 관리번호 라벨부착 등을 준수하여 USB메모리를 사용하도록 철저히 관리하여 주시기 바랍니다. (권고)